Resposta a incidentes usando a IA generativa

Aqui apresento uma simulação de uma resposta a incidentes (IR). Irei fazer o papel de um analista de segurança da informação lidando com incidentes do início ao fim, detectando, contendo e analisando como responder a esses incidentes, gerando relatórios pós-incidente e garantindo que a empresa permaneça resiliente contra ameaças.

Simulação:

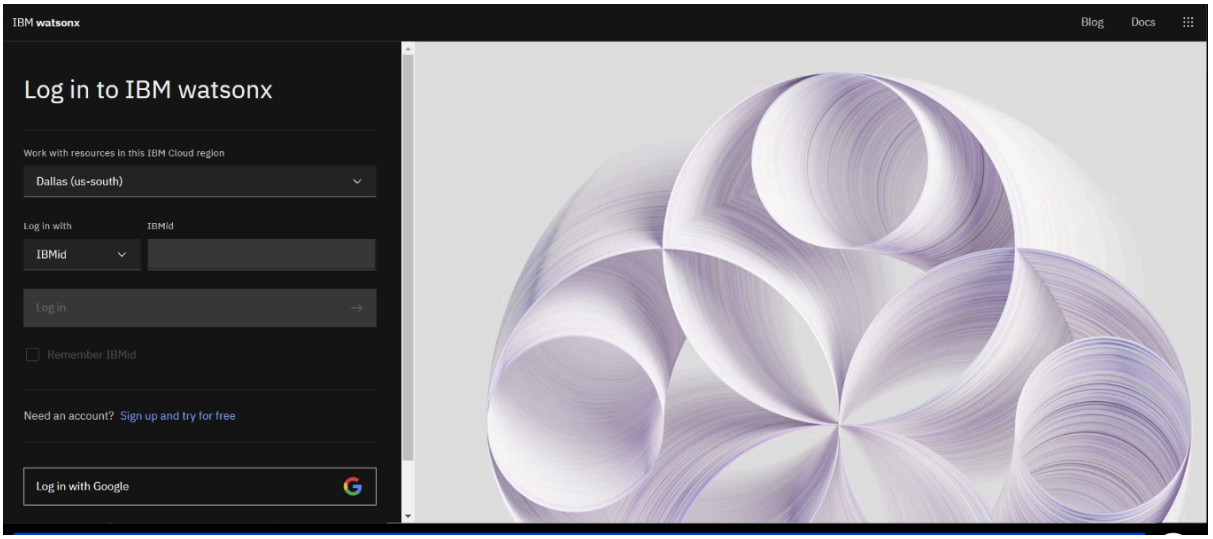
Hoje recebi um alerta automatizado de minha ferramenta de gerenciamento de informações e eventos de segurança (SIEM) que havia ocorrido uma atividade de rede incomum na última hora, incluindo eventos de escalada de privilégio.

Decido investigar procurando pistas em três conjuntos de logs relevantes:

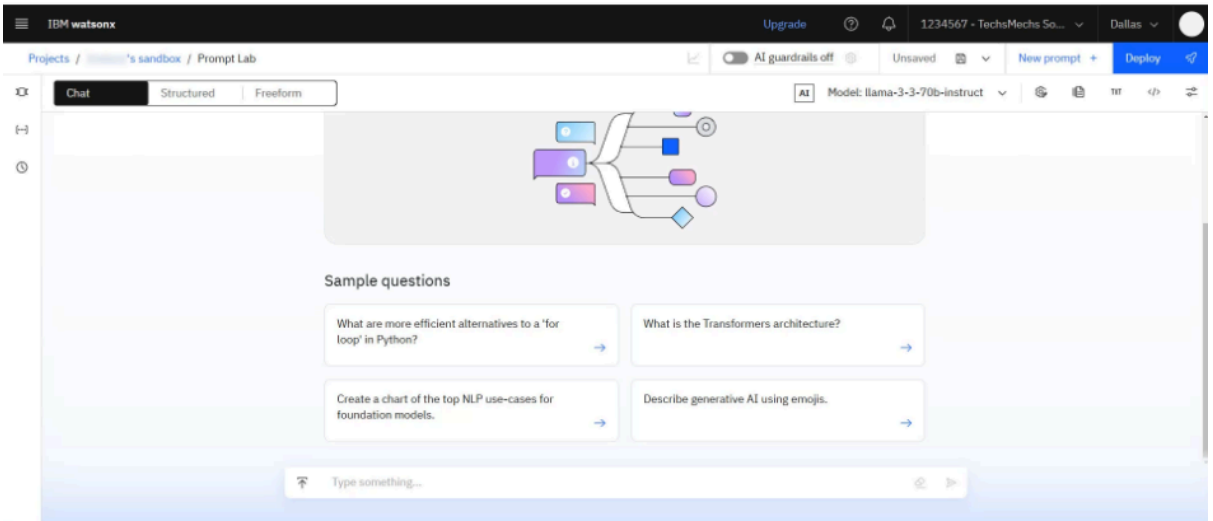
- Logs do Firewall
- Logs do terminal Microsoft Windows
- Logs da nuvem

No passado eu realizaria uma investigação como essa manualmente. Eu extrairia todos os logs dos servidores e em seguida executaria inúmeros comandos em um terminal para identificar padrões suspeitos. Mas hoje com avanço da tecnologia e com a ajuda da IA gerativa posso usar ferramentas que vasculham rapidamente os logs e resumem as principais descobertas em linguagens simples. Para isso, usarei o IBM watsonx.

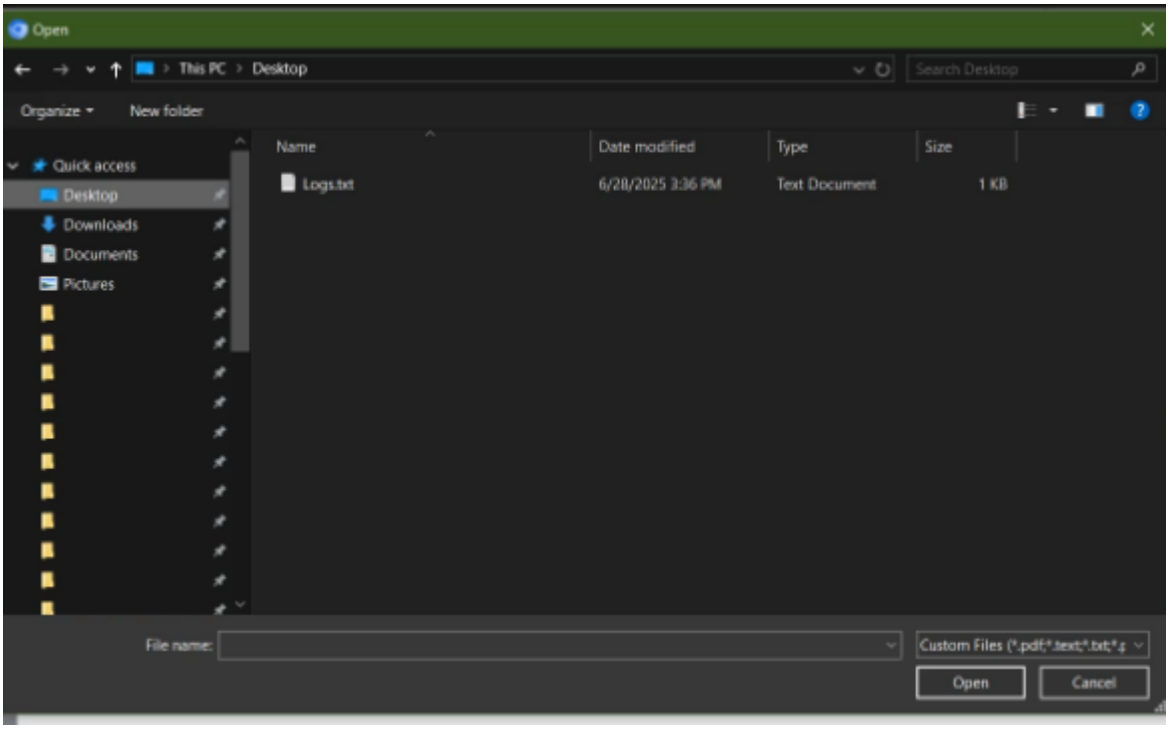
Primeira tarefa: Resumir logs para identificar atividades suspeitas.
Usarei o IBM watsonx para resumir os logs e destacar quaisquer eventos que possam indicar um incidente.

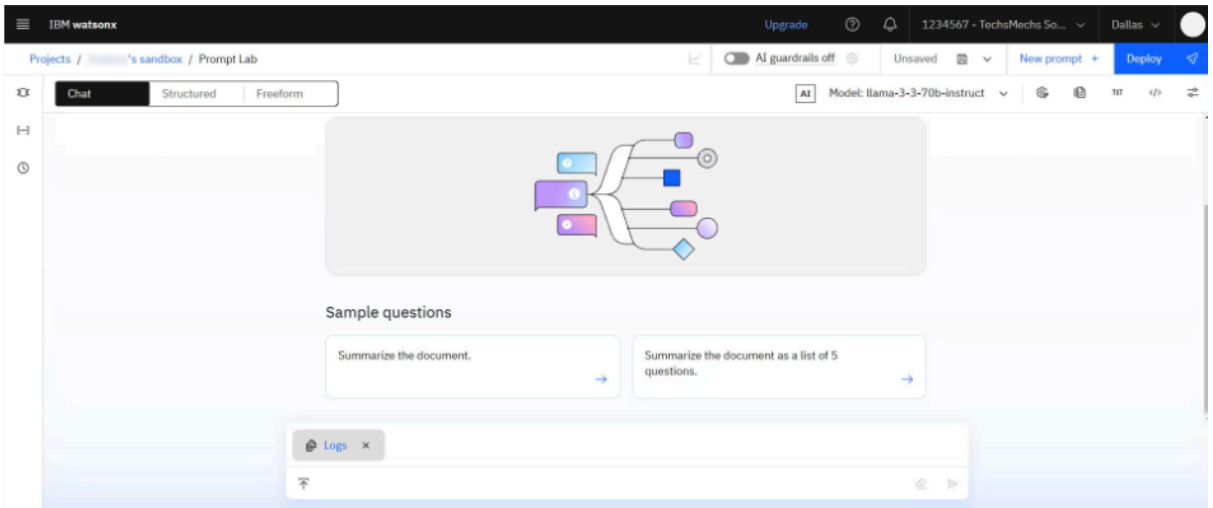


Dentro do IBM watsonx irei trabalhar no Prompt Lab que me oferece uma interface de bate-papo completa selecionando Open Prompt Lab.



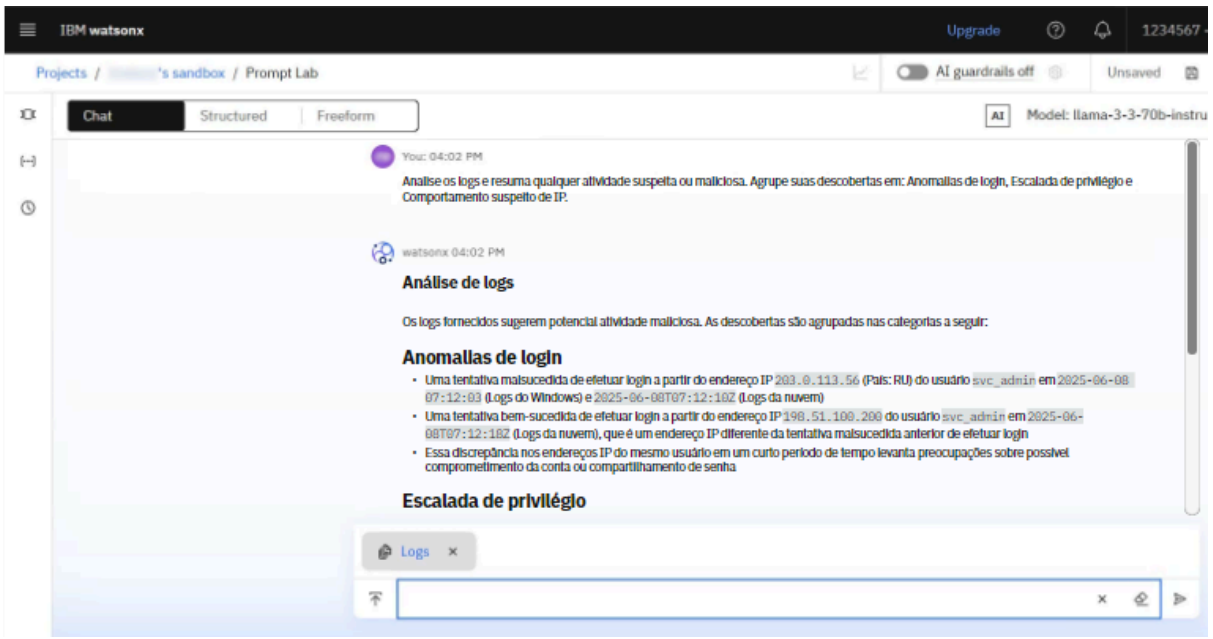
Irei fornecer os logs para o watsonx fazendo um upload do arquivo.





Pronto agora que carreguei o arquivo, vou usar um prompt para que ele analise os logs para mim.

Prompt: “Analise os logs e resuma qualquer atividade suspeita ou maliciosa. Agrupe suas descobertas em Anomalias de login, Escalada de privilégios e comportamento suspeitos de IP.”



Pronto, em segundos é feito o resumo e destacado as principais descobertas.
Na **sessão anomalias**, mostra que o watsonx encontrou duas tentativas de efetuar login do mesmo usuário: svc_admin. Porque essas tentativas são incomuns? Elas ocorreram a partir de dois endereços IP diferentes. Uma tentativa mal-sucedida da Rússia seguida por uma tentativa bem-sucedida da Holanda, com diferença de segundos entre elas. O usuário svc_admin não poderia ter se deslocado entre os locais tão rapidamente, portanto, um invasor pode ter comprometido a conta.

A **sessão escalada de privilégio** mostra que uma nova conta de administradores de domínio foi criada, que é uma conta de administrador. Esse resultado é particularmente preocupante porque, com uma conta de administrador o invasor possui acesso persistente. Se alguém comprometeu a svc_admin conta ou a usou maliciosamente, pode indicar uma ameaça interna.

A **sessão comportamento suspeito de IP** mostra múltiplas tentativas mal-sucedidas de efetuar login a partir de um IP Russo já em uma lista de bloqueios. Esse resultado sugere “Credential Stuffing” (ataque de preenchimento de credenciais) que é quando invasores usam ferramentas para injetar automaticamente credenciais roubadas em páginas de login para ter acesso a conta de alguém.
E como saída também pode indicar ataque de força bruta, que é quando os invasores fazem uso de tentativa e erro experimentando diversas senhas até encontrar uma que funcione.

Tarefa 2: Classificar um incidente por tipo.

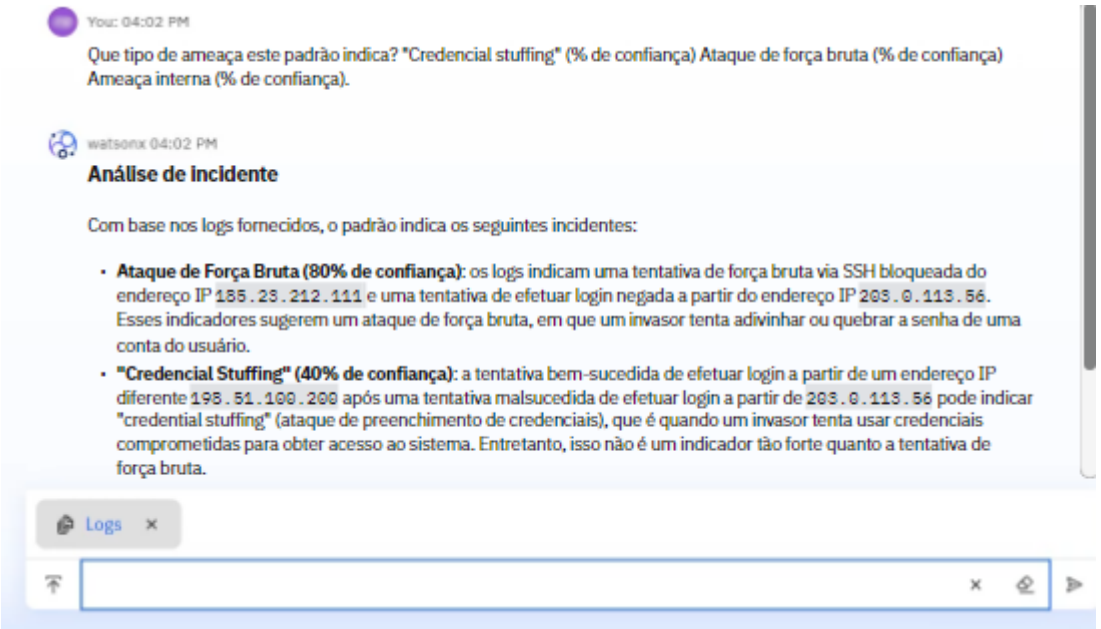
É fundamental classificar o incidente para poder determinar a resposta adequada.

A evidência sugere que os eventos incomum provavelmente fazem parte de um de incidente de segurança.

Mas que tipo de incidente é esse?

Com base no análise dos logs, a suspeita é de ter acontecido um “Credential Stuffing” (ataque de preenchimento de credenciais), um ataque de força bruta ou uma ameaça interna mas ainda não tenho certeza de qual é então usarei a IA para me ajudar nessa identificação exata.

Prompt: “Que tipo de incidente esse padrão indica? “Credential Stuffing” (% de confiança), Ataque de força bruta (% de confiança), Ameaça interna (% de confiança)”



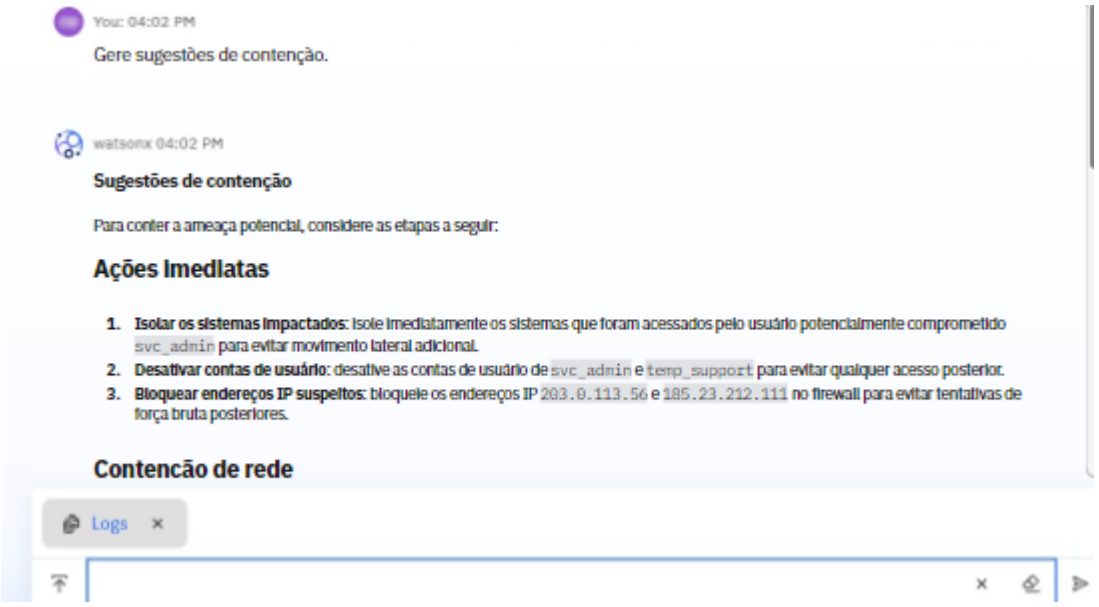
A saída lista os níveis de confiança indica a probabilidade de o incidente ser um dos dois tipos que eu mencionei. O mais provável é um ataque de força bruta, o que faz sentido dada as repetidas tentativas mal sucedidas de efetuar login.

Importante: A inteligência artificial (IA generativa) pode sugerir as categorias de incidentes, mas somente um humano pode validá-las por meio de investigações completas e considerar todo o contexto apropriado. Então é importante investigar mais para confirmar a saída verificando os logs e fazendo varreduras nos terminais para confirmar realmente que foi um ataque de força bruta é o tipo de incidente mais provável.

Tarefa 3: Determinar etapas para contenção.

Sabendo que foi um ataque de força bruta usarei a IA para gerar sugestões de contenção.

Prompt: “Gere sugestões para contenção de ataques por força bruta”



A saída lista muitas etapas de contenção que parecem razoáveis. Em resumo, tenho que desativar a conta de destino svc_admin e isolar os sistemas potencialmente impactados. Essas etapas ajudam a parar tentativas contínuas de força bruta e a evitar escalada de privilégio se o ataque for bem-sucedido.

Existe uma etapa chave que falta na saída: Redefinir as senhas das contas privilegiadas caso o invasor as tenha comprometido. Esta missão destaca a importância da supervisão humana ao usar a assistência da IA generativa.

Tarefa 4: Gerar um relatório de incidente

Aqui usarei a IA para gerar um relatório pós-incidente. De acordo com o plano de resposta a incidentes, o relatório deve incluir uma linha do tempo, as etapas realizadas e as etapas pós-incidente para notificar as partes interessadas e evitar incidentes semelhantes.

o prompt será:
“Elabore um relatório de incidente abrangendo a linha de tempo, as ações tomadas e as próximas etapas.”

Relatório de Incidente

ID do Incidente: IR-2025-06-08-001 **Tipo de Incidente:** Possível violação de segurança **Data:** 2025-06-08 **Tempo:** 07:11:45Z - 07:15:35Z

Linha de tempo dos eventos

1. **2025-06-08T07:11:45Z:** o firewall bloqueou o tráfego recebido do endereço IP `203.0.113.56` (País: RU) devido à correspondência da lista de bloqueios.
2. **2025-06-08T07:12:03** os logs do Windows registraram uma tentativa malsucedida de efetuar login a partir do endereço IP `203.0.113.56` do usuário `svc_admin`.
3. **2025-06-08T07:12:10Z:** os logs da nuvem registraram uma falha ao efetuar login a partir do endereço IP `203.0.113.56` do usuário `svc_admin`.
4. **2025-06-08T07:12:18Z:** os registros da nuvem registraram um login bem-sucedido a partir do endereço IP `198.51.100.200` do usuário `svc_admin`.
5. **2025-06-08T07:11:45Z:** o firewall bloqueou o tráfego recebido do endereço IP `185.23.212.111` (País: NL) devido a uma tentativa de força bruta via SSH.
6. **2025-06-08 07:15:22:** os logs do Windows registraram a criação de um novo usuário `temp_support` por `svc_admin`.
7. **2025-06-08 07:15:35:** os logs do Windows registraram a adição de `temp_support` ao grupo de Administradores de domínio por

A saída resume a linha de tempo, as ações tomadas e as próximas etapas conforme solicitado. Com a ajuda da IA concluí um primeiro rascunho eficaz em uma fração do tempo que teria gasto para escrevê-lo de outra forma.
A IA generativa auxilia na documentação, mas ela não pode assegurar precisão, alinhamento com a política ou completude. Essas partes somente um humano pode fazer.

Conclusão

Com a assistência da IA generativa solucionei um incidente de segurança com sucesso.
Analisando milhares de linhas de log de forma rápida foi possível identificar uma possível atividade maliciosa de ataque de força bruta.
Determinei etapas para conter o incidente e gerei o primeiro rascunho útil para produção de um relatório de incidente.

Paulo Cesar é formado em Segurança da Informação, apaixonado por tecnologia, análise Forense Computacional e OSINT.